ClickFix First Aid: security and integration review

Role: cyber security and integration review of the architecture notes, the v0.1.0 security review, the bypass harness, and the generated Node test suite.
Date checked: 24 October 2026.
What was not available: the extension, engine, rules, and PowerShell sources. Findings about those components are therefore design and coverage findings, not a completed source audit.

No application HTTP API, WebSocket, or third-party SDK appears in the uploaded code. The only network listener is the harness, bound to `127.0.0.1`. The product's live integration surface is the browser platform, Chrome extension APIs, and the recovery guide's official destinations.

Verdict

The highest risks are not missing network endpoints. They are trust-boundary and fail-open defects already identified in the security review, plus tests that can pass against mocks stronger than the real platform.

The generated suite is useful as a contract. It is not evidence that the extension resists forged events, storage races, or clipboard bypasses. Those 53 cases have not been run against production code. `npm audit` on the pinned test lockfile reported zero known vulnerabilities on 24 October 2026. That does not cover the unpublished extension dependencies.

Security findings

Application design

Area	Finding	Coverage in the generated tests	Residual risk
Authentication	The reported page-to-extension channel is an unauthenticated DOM event. A page or frame can forge a trusted overlay.	Channel tests inject an `authenticate` callback. They prove the desired interface, not that production rejects a page event.	Auth bypass remains until the real receiver ignores page-origin events and recomputes verdicts itself.
Fail-open control	A warning leaves dangerous text on the clipboard. Several report classes never reach a block.	Detector tests require hold or block for remote executor cases. They are not bound to the engine.	A green mock does not close this gap.
Input integrity	Clipboard arguments can be stringified twice, so the checked value and the written value can differ. `items.add` is a separate write path.	Clipboard tests require one conversion and cover `setData`, `items.add`, and `execCommand`.	Still needs the real wrappers and a Chromium clipboard read.

Area	Finding	Coverage in the generated tests	Residual risk
Environment integrity	Indexed array writes and regex state can be intercepted from the page realm, emptying match lists.	One subprocess test poisons prototypes and expects an unchanged verdict.	Must run inside the page realm against the real engine. Node's realm is not the page's realm.
Output handling	Page-supplied text can be shown in the extension overlay.	One test requires the production preview node to expose the text without creating elements.	Fails closed until `previewElement()` is bound. Phone numbers and URLs still need a product decision: quarantine, do not merely escape.
Settings integrity	A stale object can be written back, dropping another tab's change.	Tests use an atomic `storage.update`.	`chrome.storage` does not document that primitive. A passing mock can hide a real lost update.

Chrome's own content-script documentation warns that a script in the page's `MAIN` world can be reached and interfered with by the host page (Chrome content scripts manifest). That is the root of the coercion and prototype findings. Isolated-world code should own the verdict. Page-world code should only forward already-captured bytes.

Test suite and harness

- Fixture checks execute a fixed local allowlist through `vm.runInContext`. That is acceptable only for those reviewed files. jsdom's own security policy says its sandbox is not a boundary for untrusted HTML, and there are no published jsdom advisories (jsdom security policy). Do not point this runner at pages fetched from the network.
- `whatwg-encoding@3.1.1`, pulled in by jsdom 24.1.3, is deprecated in favor of `@exodus/bytes`. The install warning is a maintenance risk, not a confirmed vulnerability. Keep the lockfile and rerun `npm audit` on each dependency bump.
- `run.mjs` reads a URL path segment under a fixed directory and listens only on loopback. Keep that bind address. Before any shared or CI use, allow only basenames from a fixed page list so a crafted path cannot leave that directory.
- The adapter preflight checks that declared files exist. It does not prove those files are the ones the tests call. Review the adapter in CI.

Platform and endpoint status

Checked against current official documentation. "Current" means the documented interface still exists. It does not mean every browser builds it identically.

Integration	Current status	Action
`Clipboard.writeText`, `write`, `readText`	Current Async Clipboard API. Secure context only. Writes can reject with `NotAllowedError` when activation or permission is missing (MDN Clipboard API).	Keep these hooks. Test both granted permission and rejection. Do not assume a write from an `http:` page works.

Integration	Current status	Action
`clipboard-write` permission	The 24 June 2026 Clipboard editor's draft says this permission was removed from the write algorithms, while another section still defines it (Clipboard API and events).	Do not hard-code one permission name as the security boundary. Assert user activation and the actual `NotAllowedError` behavior per browser.
`document.execCommand("copy")`	Deprecated and not part of a current standard (MDN execCommand). Implementations that still support it must dispatch the copy event (Clipboard API and events).	Do not delete this hook because the API is deprecated. Track removal in the browser matrix and keep the event hook until real usage disappears.
`DataTransfer.setData` and `items.add`	Both are current clipboard-event operations in the same draft.	Hooking only `setData` is incomplete relative to the current event model.
`chrome.storage.local`, `sync`, `session`, `managed`	Current as of the 11 September 2026 reference. Sync allows 120 writes per minute and 1,800 per hour. Excess writes reject. The sustained-write quota is deprecated (chrome.storage).	No atomic read-modify-write is documented. Serialize muted-site updates in the service worker. Handle quota rejection explicitly.
`chrome.runtime` messaging and service workers	Current extension model. A service worker is ephemeral. `runtime.sendMessage` does not target content scripts; `tabs.sendMessage` does (chrome.runtime).	Do not keep verdict state only in a page or a sleeping worker. Retest after an idle worker restart.
`chrome.scripting.executeScript` worlds	`MAIN` and `ISOLATED` are current, with `MAIN` available since Chrome 95 (chrome.scripting).	Treat `MAIN` as untrusted. Manifest V3 also disallows remotely hosted extension code (Manifest V3 overview).
Manifest V2	Chrome's MV2 runtime reference says MV2 extensions were removed from the Chrome Web Store on 31 August 2026 (chrome.runtime MV2 reference).	Confirm the uploaded manifest is MV3 before any store release. The manifest was not in this upload.
Recovery destinations	Not called by code. They are user guidance and can rot without breaking the extension.	See the table below. Recheck on a schedule; do not scrape signed-in pages.

Recovery destinations checked

Guide topic	Live official destination	Status on 24 October 2026
Google devices	Manage devices	Path still matches: Security and sign-in, Your devices, Manage all devices.
Microsoft sign-out	Sign out everywhere	Still under Advanced security options. Up to 24 hours. Xbox remains an exception.
Facebook sessions	Log out on another device	Accounts Center path remains. Select all is still required for every session.

Guide topic	Live official destination	Status on 24 October 2026
WhatsApp linked devices	About linked devices	Feature remains. Android and iPhone entry points differ, so one generic path is not enough.
Telegram sessions	Active sessions	Active sessions remain. Telegram's own UI text still says a newly connected device cannot terminate older sessions for a few hours (Telegram translations).
Discord	Securing your account	Official guidance still leads with a password change because it invalidates the current token. A Devices screen was not confirmed.
Defender offline scan	Virus and threat protection	Current label is Microsoft Defender Antivirus (offline scan). This page gives no 15-minute duration. Drop that figure.
India reporting	National Cyber Crime Reporting Portal	Portal responds and still directs financial-fraud victims to 1930.
Aadhaar biometric lock	UIDAI authentication guidance	Biometric lock remains. Current routes include the Aadhaar app and UIDAI web services. A registered mobile is still required. Do not present mAadhaar as the only route.

Instagram's exact help page was not reconfirmed in this pass. Keep it marked unverified.

Integration test strategy

Run these as a separate job from unit tests. A mock cannot establish browser permission, world isolation, or storage concurrency.

1. **Bind the contract to source.** Point `CLICKFIX_ADAPTER` at modules that import the real detector, hook, receiver, analyzer, and settings code. Fail the job if the adapter reimplements policy. Review the adapter diff.
2. **Browser matrix, not just one Chromium build.** Cover current stable Chrome and one previous stable release, plus the extension's minimum declared version. Repeat on an `https:` fixture and an `http:` fixture. Expect Clipboard API writes to fail outside a secure context, and confirm the extension still records that failure instead of reporting success.
3. **Activation and timing.** In a real click handler, compare an immediate `writeText` with a `ClipboardItem` whose blob promise resolves after the activation window. Assert the browser error and the extension state. This is the live check for the deferred-write defect.
4. **World startup.** Load the unpacked MV3 extension with `document_start` injection. Confirm the isolated listener exists before page scripts run, then confirm a page listener cannot suppress the extension UI. Restart the service worker and repeat one copy. The worker must not be required to stay awake for the verdict.
5. **Storage stability.** Use real `chrome.storage`, not the in-memory lock. Run two tabs mutating muted sites while a popup toggles another field. Assert no lost key. Then exceed the documented sync write ceiling and assert a visible, retried failure rather than a silent rollback (chrome.storage limits).
6. **Link health, separately from security tests.** Weekly, request only the official recovery URLs above and assert HTTP 200 plus a stable phrase such as "Sign out everywhere" or "1930".

Alert on redirect to a different registrable domain. Do not automate signed-in account actions.

7. **Release gate.** Ship only when the source-bound contract is green, the Chromium job records both clipboard text and `data-state`, and the link job is green. Keep Windows checker tests on a Windows runner. They are local system checks, not network checks, and were not executed here.

What this review did not do

It did not exploit the extension, run the bypass harness in a browser, or audit unpublished source. Platform behavior outside the cited documents, including exact clipboard permission prompts in every Chrome channel, remains unverified until the matrix job runs.